

README: KIT INTEGRAL DE ENCUESTA DE CIBERSEGURIDAD Y GOBERNANZA IA

Guía de Uso Completa para Implementadores

Versión: 2.0

Fecha: Enero 2026

Clasificación: Profesional | Documento Público (Kit)

Idioma: Español

Contexto: España | Marco normativo: EU AI Act, NIS2, GDPR, ISO 27001, NIST AI RMF

Público Objetivo: CISOs, Risk Officers, Compliance Managers, CDOs, IT Directors

I. ¿QUÉ INCLUYE ESTE KIT?

Este kit integral proporciona todo necesario para evaluar madurez en ciberseguridad y gobernanza IA:

Documentos Principales (6)

1. Encuesta Integral de Ciberseguridad y Gobernanza IA (Encuesta_Integral_Ciberseguridad_IA.md)
2. 47 preguntas estructuradas en 6 módulos
3. Escala de madurez 5-niveles (Ad-hoc – Optimizado)
4. Tiempo: 45-60 minutos para completar
5.
Formato: Markdown + tabla
6.
Guía Metodológica Detallada (Guia_Metodologica_Encuesta_Aplicacion.md)
7. 6 fases de implementación (preparación, ejecución, análisis, reportería, seguimiento)
8. Técnicas de entrevista y calibración inter-evaluadores
9. Plantillas de scoring y análisis de gaps
10.
Tiempo de lectura: 2-3 horas; aplicación: 3-4 semanas
11.
Narrativa Explicativa (Tono Literario) (Narrativa_Explicativa_Encuesta_Ciberseguridad.md)
12. Reflexión propositiva sobre importancia de cada módulo
13. Tono irónico-literario pero riguroso
14. Argumentación sobre transformación organizacional
15.
Lectora: 30 minutos
16.
Marco Integrativo GQM + PRAGMATIC (Marco_Integrativo_GQM_PRAGMATIC.md)
17. Trazabilidad de objetivos – indicadores (GQM: Goal-Question-Metric)
18. Validación de viabilidad (PRAGMATIC: 9 criterios)
19. Ejemplo práctico: Fairness en credit scoring
20.
Técnico, 2-3 horas lectura
21.
Matriz de Evaluación PRAGMATIC Completa (Matriz_Evaluacion_PRAGMATIC_Completa.md)
22. 12 indicadores NIST RMF evaluados contra 9 criterios PRAGMATIC
23. Scoring por indicador (9/9 – 6/9)
24. Roadmap implementación por módulo

25.

Referencia técnica, uso específico

26.

Mapeo Normativo Detallado (Mapeo_Normativo_Detallado_Preguntas_GQM.md)

27. Cada pregunta GQM → requisitos EU AI Act, NIS2, GDPR, ISO 27001

28. Matriz trazabilidad completa

29. Roadmap cumplimiento regulatorio (Q1-Q4 2026)

30. Referencia compliance, uso específico

Formato: Markdown + tabla

Guía Metodológica Detallada (Guia_Metodologica_Encuesta_Aplicacion.md)

Tiempo de lectura: 2-3 horas; aplicación: 3-4 semanas

Narrativa Explicativa (Tono Literario) (Narrativa_Explicativa_Encuesta_Ciberseguridad.md)

Lectora: 30 minutos

Marco Integrativo GQM + PRAGMATIC (Marco_Integrativo_GQM_PRAGMATIC.md)

Técnico, 2-3 horas lectura

Matriz de Evaluación PRAGMATIC Completa (Matriz_Evaluacion_PRAGMATIC_Completa.md)

Referencia técnica, uso específico

Mapeo Normativo Detallado (Mapeo_Normativo_Detallado_Preguntas_GQM.md)

Herramientas (3)

31. Plantilla Excel: IGM + ROI (Plantilla_Excel_IGM_ROI_Calculo.md)

32. Cálculo automatizado de madurez (IGM 1.0-5.0)

33. ROI cuantificado usando FAIR model

34. 5 hojas: Scoring, Gaps, ROI, Dashboard, Assumptions

35.

Uso: Análisis post-survey; decision-making

36.

Plantilla Reporte Ejecutivo (PowerPoint) (Plantilla_Reporte_Ejecutivo_PowerPoint.md)

37. 12-15 slides listos para adaptar

38. Incluye narrativa para cada slide

39. Diseño profesional, aprobado para Board

40.

Uso: Presentación a ejecutivos; 20-30 min

41.

README (Este archivo) (README_Kit_Encuesta.md)

42. Guía de uso integral

43. Roadmap de implementación

44. FAQs

45. Soporte

Uso: Análisis post-survey; decision-making

Plantilla Reporte Ejecutivo (PowerPoint) (Plantilla_Reporte_Ejecutivo_PowerPoint.md)

Uso: Presentación a ejecutivos; 20-30 min

README (Este archivo) (README_Kit_Encuesta.md)

II. QUICK START (5 MINUTOS)

Si tienes 5 minutos ahora:

46. Lee esta sección (README)

47. Decide: ¿Eres el "Sponsor" o "Executor"?

48. Salta a sección correspondiente (III o IV abajo)

¿Eres Sponsor? (CFO, Board, C-level)

– Lee: SLIDE 1 de Plantilla PowerPoint

– Ask: "¿Quién coordina esta encuesta?"

– Approve: Budget (~ €50-100K para aplicación completa) + executive sponsor time

¿Eres Executor? (CISO, Risk Officer, Project Manager)

- Lee: Secciones IV-VI de este README
- Descarga: Todos 9 archivos del kit
- Start: Timeline de 4-6 semanas (Phase 1)

III. PARA SPONSORS (EJECUTIVOS / BOARD)

¿Por Qué Hacer Esta Encuesta? (2 minutos)

Mandato regulatorio: EU AI Act entra en vigor febrero 2026. AESIA (regulador español) audita agosto 2026. Sin gobernanza documentada = sanciones €35M+.

Oportunidad financiera: €1.35M annual savings (risk reduction) + 178% ROI. Payback 4.3 meses.

Competitividad: Organizaciones líderes en madurez NIST 3.5+. Nosotros estamos en 2.48 (extrapolado).

Inversión Requerida

OPCIÓN A: Aplicación rápida (6 semanas, €50K)

- Internal resources only
- 1 CISO + 2 staff + external auditor (part-time)
- Baseline assessment; roadmap draft

OPCIÓN B: Aplicación completa (12 semanas, €150K) - RECOMENDADA

- Internal resources (same as A)
- External consulting (framework + training + validation)
- Detailed remediation roadmap
- Ready for AESIA audit

OPCIÓN C: Transformación total (24 semanas, €500K+)

- Options A + B + full implementation
- Staff augmentation; vendor integration
- Madurez 3.5+ achieved by Dec 2026

Recomendación: Opción B (€150K) para baseline + roadmap; luego Opción C (€500K) si aprobado.

Decisión Requerida Hoy

- ☐ Aprueba presupuesto (€150K mínimo)
- ☐ Designa Executive Sponsor (CFO o CISO)
- ☐ Asigna tiempo coordinador (1 FTE por 3 meses)
- ☐ Comunica prioridad organizacional ("esto es importante")

Siguiente: Sponsor contacta Project Manager (sección IV)

IV. PARA PROJECT MANAGERS / COORDINADORES

Tu Rol

Eres el "quarterback" que ejecuta:

- Programación de entrevistas
- Recopilación de evidencia
- Scoring de indicadores

- Análisis de gaps
- Presentación a Board

Timeline Recomendado

SEMANA 1: PREPARACIÓN

- Task 1: Read README + Guía Metodológica (2 horas)
- Task 2: Constituir equipo evaluador (7-10 personas)
 - 1 Líder (CISO/CRO)
 - 2 Especialistas NIST/Cyber
 - 1 Especialista IA/Data
 - 1 Compliance Officer
 - 1 Líder Negocio
 - 1 IT Ops
 - 1 Comunicador
- Task 3: Capacitación equipo (4 horas, usando documentos 3-5 del kit)
 - NIST AI RMF intro (1h)
 - GQM methodology (1h)
 - Calibración (2h - hacer ejercicio conjunto)
 - Hoja de cálculo y herramientas (hands-on)
- Task 4: Comunicación a stakeholders
 - Email: "In 2 weeks, we'll evaluate cybersecurity maturity"

SEMANA 2-4: EJECUCIÓN DE ENCUESTA

- Session 1 (Week 2): GOVERN + MAP modules (4h, Lunes)
 - 6-8 respondentes (IT, Negocio, Compliance)
- Session 2 (Week 3): MEASURE + Vulnerabilities (4h, Miércoles)
 - 6-8 respondentes (DS, Security, Ops)
- Session 3 (Week 3-4): SIEM + Capacitación (4h, Viernes)
 - 6-8 respondentes (SOC, Training, HR)
- Calibración inter-evaluadores (Week 4): 2h
 - Todos evaluadores; reconciliar discrepancias
- Recopilación evidencia (ongoing):
 - Políticas, reportes, logs, dashboards

SEMANA 5: ANÁLISIS

- Task 1: Entrada datos en plantilla Excel (2h)
 - Todos indicadores scored; IGM auto-calculated
- Task 2: Análisis de gaps (4h)
 - Identificar top 10 gaps; prioritarizar
- Task 3: ROI calculation (3h)
 - FAIR model; financials sensible?
- Task 4: Crear draft reporte (4h)
 - Slides PowerPoint personalizadas

SEMANA 6: PRESENTACIÓN Y APROBACIÓN

- Internal review with Sponsor + Leadership (1h)
- Adjust slides based on feedback (2h)
- Present to Board (30 min presentation + 10 min Q&A)
- Capture approval + next steps
- Archivo documentación (audit trail)

TOTAL: 30-40 horas PM effort + 20-30 horas evaluador effort = 50-70 horas total

Herramientas Clave

Documento 1: Encuesta (preguntas)

Documento 2: Guía Metodológica (protocolo)

Herramienta 1: Excel (scoring + ROI)

Herramienta 2: PowerPoint (presentación)

Checklist Pre-Encuesta

- ☐ Equipo constituido y capacitado
- ☐ Respondentes confirmados (10-15 personas por módulo)
- ☐ Calendarios bloqueados (4h sesiones, en próximas 3 semanas)
- ☐ Documentos compartidos (políticas, reportes, dashboards disponibles)
- ☐ Excel descargado y probado (fórmulas funcionan)
- ☐ PowerPoint template descargado (editable)
- ☐ Comunicación: "Gracias por participar; es importante para cumplimiento"
- ☐ Respaldo: Alguien toma notas, otro toma fotos de documentos

V. PARA CIBERSEGURIDAD / RIESGO (IMPLEMENTADORES TÉCNICOS)

Tu Rol

Eres el "subject matter expert" que:

- Entiendes frameworks (NIST, GQM, PRAGMATIC)
- Respondes preguntas sobre seguridad/IA
- Proporcionas evidencia (logs, reportes, resultados tests)
- Ayudas a interpretar resultados

Preparación (1-2 horas antes de encuesta)

Leer:

- ☐ Encuesta Integral (skim preguntas de tu módulo: GOVERN/MAP/MEASURE/MANAGE)
- ☐ Marco GQM (entender Goal → Question → Metric)
- ☐ Narrativa (por qué importa cada indicador)

Reunir evidencia:

- ☐ Políticas de ciberseguridad (busca más reciente)
- ☐ RACI documentado (si existe)
- ☐ Risk registers (últimos 3 trimestres)
- ☐ Incident logs (SIEM output)
- ☐ Pentesting reports (año pasado)
- ☐ Audit results (compliance, internal)
- ☐ Training data (enrollment, completion rates)
- ☐ MTTR/MTTD metrics (si tracked)

Estar preparado para:

- "¿Cómo miden fairness?" → Mostrar dashboard fairness metrics (o admitir falta)
- "¿Cuál es MTTD para anomalías?" → Mostrar SIEM alert data (o admitir que no está optimizado)
- "¿RACI documentado?" → Mostrar documento formal (o explicar dónde está el gap)

Durante Entrevista

Tu rol NO es defender estado actual; es ser honesto.

Pregunta: "¿Tienen política IA formal?"

MAL: "Sí, es muy robusta" (sin prueba)

BIEN: "No formal aún; tenemos borradores pero sin aprobación Board"

Pregunta: "¿Cómo miden bias?"

MAL: "Nuestros modelos son fair" (sin métrica)

BIEN: "No tenemos audit formalizado; es una brecha que hemos identificado"

Pregunta: "¿Qué es MTTD actual?"

MAL: "Creo que ~1 hora típicamente"

BIEN: "No lo medimos actualmente; podría ser 2-8 horas; necesitamos SIEM mejorado"

Honestidad – Credibilidad – Approval de presupuesto

Post-Encuesta (Remediación)

Una vez scores y gaps están claros, tu equipo:

49. Prioriza Top 5 gaps (usando matriz criticidad × esfuerzo)

50. Propone soluciones (por gap):

GAP: "No miden fairness"

SOLUCIÓN: Implementar Aequitas platform; quarterly audits

COSTO: €80K

TIMELINE: 4 semanas

OWNER: CDO

BENEFIT: €400K risk reduction (FAIR model)

51. Crea roadmap de 12 meses (phases: P1 quick wins, P2 strategic)

52. Monitorea progreso (monthly tracking, trending)

VI. ESTRUCTURA DE FICHEROS

¿Cómo organizar los documentos?

Carpeta Raíz: /Kit_Encuesta_Ciberseguridad_IA_2026/

- DOCUMENTOS_CONCEPTUALES/
 - Encuesta_Integral_Ciberseguridad_IA.md
 - Narrativa_Explicativa_Encuesta_Ciberseguridad.md
 - Marco_Integrativo_GQM_PRAGMATIC.md
 - Matriz_Evaluacion_PRAGMATIC_Completa.md
- GUIAS_IMPLEMENTACION/
 - Guia_Metodologica_Encuesta_Aplicacion.md
 - Mapeo_Normativo_Detallado_Preguntas_GQM.md
 - README_Kit_Encuesta.md
- HERRAMIENTAS/
 - Plantilla_Excel_IGM_ROI_Calculo.md
 - Plantilla_Reporte_Ejecutivo_PowerPoint.md
 - [Descarga plantillas reales: .xlsx, .pptx]
- RESULTADOS/ (crear durante aplicación)
 - Scoring_Indicadores.xlsx
 - Análisis_Gaps.xlsx
 - ROI_Cálculo.xlsx
 - Reporte_Board.pptx
 - Evidencia/
 - Políticas_Firmadas.pdf
 - Reportes_Risk.pdf
 - Logs_Incidentes.csv
 - Documentación_Auditoría.pdf

VII. PREGUNTAS FRECUENTES (FAQs)

¿Cuánto tiempo toma?

Baseline (survey solamente): 3-4 semanas

Completo (survey + análisis + roadmap): 6-8 semanas

Implementación roadmap: 12 meses (paralelo, no secuencial)

¿Quién decide las puntuaciones (scoring)?

Respuesta: Consenso evaluador (7-10 personas).

Proceso: Cada persona puntúa independientemente; discuten discrepancias; votan si no hay acuerdo; median si diferencias >1 punto.

NO es: Auto-scoring de IT. NO es: "El CISO decide todo"

SÍ es: Proceso colaborativo, diverse perspectives.

¿Qué pasa si puntuaciones muy bajas (1-2)?

Es NORMAL. Mayoría orgs están en 1.5-2.5 en GQM+PRAGMATIC.

Significado: "Tenemos oportunidad de mejorar; esto no es crisis"

Acción: "¡Excelente—ahora sabemos por dónde empezar!"

¿Puedo compartir resultados públicamente?

NO para scores crudos (competencia risk; regulatory visibility).

SÍ para resultados agregados anonimizados (benchmark data).

Ej: "65% orgs financieras España están Nivel 2-3 en fairness"

¿Qué pasa post-encuesta?

Paso 1: Board approve roadmap + presupuesto

Paso 2: Ejecutar Prioridad 1 gaps (Q1-Q2 2026)

Paso 3: Re-assess (December 2026)

Paso 4: Iterate → target 3.5-4.0 (2027+)

¿Necesito auditor externo?

NO para baseline (survey interna OK).

SÍ recomendado para:

- └ Validación de scoring (auditor confirma puntuaciones justas)
- └ Evidencia compliance (AESIA audits)
- └ Quarterly checkpoints (mantener disciplina)

Costo: €5-10K auditor por ciclo.

ROI: Invaluable (regulatory credibility).

VIII. RECURSOS Y REFERENCIAS

Documentos Relacionados (Externos)

EU AI Act (completo):

<https://artificialintelligenceact.eu/>

NIST AI RMF 1.0:

<https://nvlpubs.nist.gov/nistpubs/ai/nist.ai.100-1.pdf>

NIST CSF 2.0:

<https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf>

ISO/IEC 27001:2022:

<https://www.iso.org/standard/27001>

FAIR Institute:

<https://www.fairinstitute.org/>

AESIA (regulador español):

<https://www.aesia.es/> [En construcción; inicio oficial Feb 2026]

INCIBE (agencia ciberseguridad España):

<https://www.incibe.es/>

Herramientas Complementarias (Opcionales)

Scoring/Assessment Tools:

- └ Archer (ServiceNow): Enterprise GRC
- └ MetricStream: Risk management
- └ Vanta/Drata: Compliance automation
- └ Custom Excel: (recomendado para starts)

Fairness Testing:

- └ Aequitas: Open source (<https://aequitas.dssg.uchicago.edu/>)
- └ Fairness Indicators (TensorFlow)
- └ AI Fairness 360 (IBM)

SIEM + Monitoring:

- └ Splunk: Enterprise SIEM
- └ ELK Stack: Open source
- └ Datadog: Cloud-native
- └ Sumo Logic: Log management

Reporting:

- └ Tableau: Dashboards
- └ Power BI: Microsoft ecosystem
- └ Google Data Studio: Free option
- └ Custom: Excel+Python for advanced

IX. SOPORTE Y MANTENIMIENTO

Si tienes preguntas durante encuesta:

Preguntas sobre metodología:

- └ Ref: Guía Metodológica (Documento 2)

Preguntas sobre framework GQM:

- └ Ref: Marco Integrativo (Documento 4)

Preguntas sobre PRAGMATIC criteria:

- └ Ref: Matriz Evaluación (Documento 5)

Preguntas sobre normativa:

- └ Ref: Mapeo Normativo (Documento 6)

Preguntas sobre Excel:

- └ Ref: Plantilla Excel (Herramienta 1)

Preguntas sobre PowerPoint:

- └ Ref: Plantilla PowerPoint (Herramienta 2)

Mejoras Futuras (Roadmap Kit)

Q1 2027: Versión 3.0

- └ Integración con NIST CSF 2.0 (nuevo en 2026)
- └ Mapped to ISO/IEC 42001:2023 (AI governance standard)
- └ Cyber AI Profile alignment

Q2 2027: Automatización

- └ Excel → Web app (scoring en línea)
- └ Integración Zapier/API a herramientas TI
- └ Real-time trending + benchmark comparison

Q4 2027: Expansión

- └ Versión inglés (para orgs multinacionales)
- └ Versión alemán, francés (EU coverage)
- └ Industria-específica (banking, healthcare, manufacturing)

X. TÉRMINOS Y CONDICIONES DE USO

Este Kit es:

- ✓ **Gratuito:** No hay costo de licencia
- ✓ **Abierto:** Puedes adaptar, personalizar
- ✓ **Profesional:** Basado en frameworks estándar (NIST, GQM, PRAGMATIC)
- ✓ **Respaldado:** Validado contra requisitos EU AI Act, NIS2

Restricciones:

- ⚠ **Confidencialidad:** Resultados de tu encuesta son CONFIDENCIALES
- ⚠ **No Responsabilidad:** Kit no garantiza cumplimiento regulatorio (usa auditor)
- ⚠ **Adaptaciones:** Si adaptas, asegura rigor metodológico
- ⚠ **Comercial:** No se puede vender este kit; úsalo internamente

XI. CONTACTO Y RETROALIMENTACIÓN

Si necesitas ayuda:

Metodología: Ref documentación (Secciones IV-VI)
Bugs en Excel: Verificar fórmulas; sanity-check numbers
Preguntas encuesta: Leer narrativa (clarifica propósito)
Interpretación resultados: Consultar auditor externo

Si tienes mejoras/feedback:

Este kit es vivo (v2.0 en enero 2026).

Mejoras futuras incorporarán:

- └ Feedback de usuarios
- └ Cambios normativos (EU AI Act updates)
- └ Evolución NIST RMF

Si usas este kit, agradecería retroalimentación sobre:

- └ ¿Qué funcionó bien?
- └ ¿Qué fue confuso?
- └ ¿Qué faltó?
- └ ¿Resultados alcanzados? (IGM, ROI, timeline)

RESUMEN EJECUTIVO (1 MINUTO)

¿Qué es este kit?

Marco integral para evaluar madurez ciberseguridad + gobernanza IA usando NIST AI RMF.

¿Para quién?

Organizaciones España enfrentando EU AI Act (febrero-agosto 2026), NIS2, GDPR.

¿Cuánto tiempo?

Baseline: 4 semanas. Completo: 8 semanas. Implementación: 12 meses.

¿Cuánto cuesta?

Kit: Gratis. Implementación: €50-500K (depends scope).

¿Cuál es el beneficio?

€1.35M risk reduction + 178% ROI año 1; liderazgo sectorial; cero sanciones regulatorias.

¿Qué sigue?

1. Sponsor aprueba presupuesto (€150-500K)
2. Project Manager coordina encuesta (4-8 semanas)
3. Board aprueba roadmap (Q1 2026)
4. Equipo ejecuta (Q1-Q4 2026)
5. Re-assess (diciembre 2026)

¿Empezamos?

Fin de README

Guía completa para uso del Kit de Encuesta

Enero 2026 / Versión 2.0 / España

Confidencial / Uso Profesional Interno